

Security Tool Comparison Report

Tools Compared: SonarQube vs. vulnerability-scan tool

Scope: `controller.js`, `service.js`

Focus: Injection Vulnerabilities (OWASP A05)

1. Executive Summary

This report compares SonarQube and the vulnerability-scan tool based on precision, recall, false positives, and missed findings.

Key Results:

- SonarQube showed high precision but missed the SQL injection.
 - The vulnerability-scan tool detected both injection vulnerabilities after verification.
 - SonarQube provides broader quality coverage.
 - The vulnerability-scan tool performs stronger within injection detection.
-

2. Test Scope

Files Analyzed

- `controller.js`
- `service.js`

Known Vulnerabilities

- SQL Injection (`controller.js`)
 - Command Injection (`service.js`)
-

3. Precision

SonarQube

- Reported: 1 Command Injection
- No false positives observed
- Finding is valid and exploitable

Precision: High

vulnerability-scan tool

- Initially reported: 3 findings
- After verification: 2 confirmed vulnerabilities
- 1 speculative finding removed

Precision: Very High (after validation pass)

4. Recall (Injection Category)

SonarQube

- Detected: Command Injection
- Missed: SQL Injection

Recall: Moderate

vulnerability-scan tool

- Detected: SQL Injection
- Detected: Command Injection

Recall: High (within injection scope)

Limitation: Does not analyze code quality, maintainability, or best practices.

5. False Positives

- **SonarQube:** None observed in this test.
- **vulnerability-scan tool:** One speculative finding removed during verification.

The verification stage improves reliability and reduces noise.

6. Missed Issues

SonarQube

- Missed SQL Injection
Possible reasons:
 - Limited taint propagation
 - Rule configuration or pattern limitations

vulnerability-scan tool

- Does not evaluate:
 - Code quality
 - Maintainability
 - Architectural concerns

Scope is limited to injection vulnerabilities.

7. Comparative Summary

Category	SonarQube	vulnerability-scan tool
Precision	High	Very High
Recall (Injection)	Moderate	High
Scope Breadth	Broad (quality + security)	Injection-focused
False Positives	None observed	Reduced after verification

8. Conclusion

SonarQube correctly detected the command injection but missed the SQL injection.

The vulnerability-scan tool detected both injection vulnerabilities and demonstrated stronger recall within its defined scope.

SonarQube offers broader static analysis capabilities, while the vulnerability-scan tool provides deeper focus on injection detection.

Using both tools together would provide more balanced security and quality coverage.